B/S 体系软件设计
企业审批系统
中期设计文档



姓名：章钰柯　　学号：3240103524
专业班级：软件工程 2402
指导教师：胡晓军
2026—2027 学年秋冬学期
2026 年 11 月 9 日

Table of Contents

1 系统范围 . . . 3
2 业务规则与权限 . . . 3
2.1. 组织与单据权限 . . . 3
2.2. 管理操作 . . . 4
2.3. 动作权限矩阵 . . . 5
2.4. 采购、差旅与报销 . . . 5
3 系统架构 . . . 6
3.1. 技术选型与模块 . . . 6
3.2. 会话与数据表示 . . . 6
3.3. 资源接口与业务载荷 . . . 7
3.4. 安全参数与失败交互 . . . 10
4 数据库设计 . . . 11
4.1. 实体关系 . . . 11
4.2. 表结构 . . . 11
4.3. 字段类型与关联约束 . . . 13
4.4. 金额、索引与删除策略 . . . 15
5 审批流程与事务 . . . 15
5.1. 提交与人员快照 . . . 15
5.2. 模板版本与重提 . . . 16
5.3. 状态与节点 . . . 16
5.4. 并发与请求重试 . . . 17
6 附件、提醒与统计 . . . 18
6.1. 附件与重复票据预警 . . . 18
6.2. 站内通知与邮件 . . . 18
6.3. 超时催办 . . . 19
6.4. 统计口径 . . . 19
7 界面设计 . . . 20
7.1. 账户与个人资料 . . . 20
7.2. 申请、待办与已办 . . . 21
7.3. 用户、部门与授权管理 . . . 22
7.4. 固定流程配置与审计 . . . 23
7.5. 采购申请 . . . 24
7.6. 差旅与自定义申请 . . . 25
7.7. 报销与审批 . . . 26
7.8. 模板配置 . . . 27
7.9. 通知与统计 . . . 28
7.10. 小程序 . . . 29
8 测试与验收 . . . 31
8.1. 测试数据与分层 . . . 31
8.2. 性能与复现 . . . 32
8.3. 需求与验收对应 . . . 32
9 部署与实施安排 . . . 33
9.1. 部署、初始化与恢复 . . . 33
9.2. 开发安排 . . . 33
9.3. 风险与处理 . . . 34
9.4. 交付与演示顺序 . . . 34

1 系统范围

系统供研发部、市场部、财务部办理采购、差旅和报销。员工保存草稿、提交申请并查询进度，审批人逐级处理待办。管理员维护组织、权限和流程模板，新增审批类型采用配置方式。桌面 Web 承担业务办理与管理配置，微信小程序承担移动办理，两端使用同一套数据和权限规则。

范围	交付功能
核心业务	注册登录、个人资料；采购、差旅、报销和自定义申请；草稿、待办、已办、历史查询
管理端	账户确认、部门与负责人、角色与数据授权、流程配置、系统配置、审计查询
业务支撑	附件预览下载、站内通知、个人与部门统计、数据备份恢复
移动端	四类申请、拍票上传、审批、进度与通知；前台自动更新、后台邮件提醒
增强功能	跨申请相同票据文件预警；当前审批节点超时催办

审批采用单人顺序处理，不包含会签、委托和循环流程。超时催办只发送提醒，不自动批准、驳回或转交。系统不处理付款、采购履约或票据真伪鉴定；采购价格人工填写，不采集电商实时价格。

本文规定拟实现的字段、交互、事务和验收条件。图中的账户、单据和统计数字均为原型示例，测试表记录预期结果，不表示功能已经完成。

2 业务规则与权限

2.1. 组织与单据权限

采用基于角色的访问控制（Role-Based Access Control，RBAC），结合申请归属、节点分配和数据授权判断范围。配置管理、正文阅读、审批和统计分别授权。

角色	授权范围	限制
普通员工	本人申请；分配给自己的节点单据及必要附件	不得自审；他人无关单据不可见
部门负责人	默认查询、阅读本部门已提交申请及必要附件并统计；本人当前待办	他人草稿不可见；跨部门正文或统计须有对应显式授权
财务审批人	分配给自己的单据；显式授予的财务统计	财务角色不开放全企业正文与票据
企业负责人	本人当前待办；显式授予的企业统计或正文范围	审批权限仍限定于当前分配节点
系统管理员	用户、部门、角色、模板、系统配置和审计	正文与票据另行授权；审批权仅来自节点分配

注册填写用户名、姓名、邮箱、密码和申请加入的部门，不接受角色或确认部门字段。账户初始为待确认，管理员确认部门后授予普通员工身份；拒绝时填写原因，用户修改资料后可重新申请。用户名去除首尾空格后按不区分大小写的规则唯一，邮箱按统一规范化值判重。用户名为 4—64 位字母、数字或下划线；姓名 1—80 字；邮箱最长 254 字符；密码 8—64 字符。前端在失焦和提交时校验，服务端重复校验并用唯一约束处理并发注册。密码使用 Spring Security 支持的哈希方式保存。

个人资料允许修改姓名、邮箱和密码，不允许自行改部门或角色。修改邮箱检查唯一性；修改密码校验原密码并撤销全部会话。待确认和已拒绝账户只开放资料、确认结果和退出入口；已拒绝账户可修改资料后重新提交账户确认申请。申请人、确认部门及操作时间均由服务端确定，客户端传入的身份或金额不能改变授权及审批路径。

部门负责人须为本部门已确认且启用的用户。账号停用、调部门或撤销审批角色前，检查负责人关系和当前、后续未完成节点；存在任务时先交接，再执行变更。交接事务记录原人、新人、原因及受影响节点，不覆盖原始人员快照，禁止交给申请人。负责人任命与部门查询权同步变更。

节点可指定普通员工或跨部门人员，其阅读权限定于分配单据，审批权限定于当前节点。审批中各节点人员可读必要材料；终态保留申请人及已处理人员的历史读取权，取消未处理人员的节点授权。他人草稿始终不可见。列表、详情、附件、统计钻取和通知跳转分别检查权限。

2.2. 管理操作

管理端按用户、部门、角色与授权、流程与系统配置、审计分区。账户状态包括待确认、已启用、已拒绝和已停用。批量操作逐人返回结果，不能因一个账户失败而隐藏其他账户的处理情况。

操作	校验与保存规则
确认与账户维护	确认部门后启用；拒绝必填原因；停用前完成任务交接。管理员重置密码时设置临时密码，要求首次登录改密，撤销全部旧会话；密码不进入审计正文
部门维护	名称唯一；新增、改名、负责人任命与交接均留痕。有启用用户或未完成任务时禁止停用；被引用部门不物理删除
角色授予与撤销	展示现有角色、变更差异和原因；停用账号或撤销管理员角色后，至少保留一个启用管理员。负责人角色与部门负责人关系同事务维护
显式数据授权	能力选正文阅读或统计；范围选指定部门或企业；有效期必填并允许提前撤销。企业授权二次确认，界面显示授予人、原因与到期时间
系统配置	采购与报销阈值、差旅阈值、固定节点主备人员、超时时长、文件限制保存版本。费用类型固定为交通、住宿、餐饮、办公、其他，不提供任意改名入口
审计查询	按操作人、对象、动作和时间筛选；显示脱敏前后值与原因。仅查询，不提供编辑删除。SMTP 凭据仅由部署环境注入

授权有效期按服务端时间判断。统计授权不隐含正文和附件权限，正文授权也不产生审批权。管理写操作统一携带 expectedConfigVersion，版本属于 system_config 的单行 row_version。用户、部门、角色集合、数据授权、模板与规则发布均先锁定该行，校验版本后修改对象、追加审计并递增版本，同事务提交。data_grant 与 user_role 不另设独立版本，集合变更由该全局版本保护；用户、部门和模板自身的 row_version 另用于检测对象编辑冲突。普通用户修改资料只递增本人 row_version。

采用全管理域版本是因为管理写入频率低，允许无关配置修改也使旧页面冲突，避免多个管理员同时撤销彼此后没有可用管理员。管理页重新读取版本和差异后由操作者再次确认，不自动重放。停用、调部门或撤销角色前，同时检查负责人关系、有效固定配置的主备引用及未完成实例；须先完成任命、发布替代配置和节点交接。提交解析与管理写入共用配置锁，不能在停用完成后新建仍引用停用人的实例。

2.3. 动作权限矩阵

表中“本人”指申请人，“节点”指被分配到该单的人员，“部门”只含本部门已提交单据，“授权”指有效的显式能力与范围。多个角色及授权来源取并集，账户限制、他人草稿禁止和不得自审优先于允许项。

动作	员工	部门负责人	财务	企业负责人	管理员
读取正文与附件	本人/节点/授权	本人/节点/部门/授权	本人/节点/授权	本人/节点/授权	本人/节点/授权
编辑、删草稿	本人	本人	本人	本人	本人
批准、驳回	当前节点	当前节点	当前节点	当前节点	当前节点
撤回审批中申请	本人	本人	本人	本人	本人
个人统计	本人	本人	本人	本人	本人
部门/企业统计	授权	本部门/授权	授权	授权	授权
组织、配置、审计	禁止	禁止	禁止	禁止	允许

管理员身份不自动产生正文阅读和审批权，也不否决其通过其他身份获得的合法节点分配。终态取消未处理人员的节点阅读来源，不取消其独立的部门或显式授权。历史姓名与部门快照用于展示，不授予当前访问权；每次请求重新读取账户状态、角色和有效授权。管理事务取得配置锁后还须重读操作者的启用状态、强制改密标志和管理员角色，不能用等待锁前的鉴权结果继续写入。待确认、已拒绝和必须改密账户只开放各自允许的账户操作，已停用账户不得使用旧会话。

2.4. 采购、差旅与报销

业务	字段与提交约束
采购	标题、原因、到货日期、部门或项目、预算、备注、明细、供应商报价与选择理由。明细含名称、规格、数量、单位、预计单价和金额，数量与单价均大于 0。非单一来源必须有至少两家供应商；每家填写名称、报价日期、整单金额及附件或文字依据。线上报价须有链接与截图。单一来源必填原因；未选最低价另填理由
差旅	标题、出发地、目的地、起止时间、目的、同行人员、交通方式、预算、备注和附件。结束不早于开始，预算不小于 0。天数按北京时间自然日计算：结束日期减开始日期加 1，同日为 1 天；保留完整时间
报销	标题、说明、关联申请、备注和费用明细。明细含类型、合法发生日期、用途、金额及票据，类型与日期必填，金额大于 0；无票时显式选择例外并填原因。关联限定本人已通过的采购或差旅，无关联时填写独立报销说明

采购和费用明细可新增、修改、删除，分别支持两行、三行以上录入，单张申请至少一条有效明细。前端即时计算合计，服务端提交时重新计算。默认每条费用至少一份票据；票据号码随每份票据选填，一条费用可挂多张票。无票与票据互斥，原因在财务审核页醒目展示。

采购按相同规格清单比较整单含税含运费报价。明细预计单价含税但不含整单另列的运费和其他费用，其他费用非零时必填说明。预计采购总额等于逐行舍入后的明细合计、运费及其他费用之和；总额须等于拟选整单报价且不超过预算。供应商打包报价由申请人分摊到明细，页面显示分摊后的合计差额，差额为零才允许提交。

报销可多次关联同一获批申请，关联只用于追溯，不扣减采购或差旅预算。获批差旅详情显示关联报销入口，报销详情展示关联差旅的地点、日期和预算摘要。审批通过不记录为已付款。

3 系统架构

3.1. 技术选型与模块

桌面端采用 Vue 3、TypeScript 和 Element Plus，小程序采用 uni-app；共用 REST 接口。后端采用 Java 17、Spring Boot 3、Spring Security 和 MyBatis-Plus，数据库采用 MySQL 8/InnoDB。Flyway 管理结构迁移，ECharts 绘制统计图。

后端采用模块化单体，划分身份组织、业务申请、流程、文件、通知和统计审计。申请、节点、审批日志和通知在同一数据库事务内更新。附件字节保存在私有卷，数据库保存元数据和绑定关系。



图 1　桌面与小程序共用业务接口，数据和任务保存在同一数据库

控制器校验输入输出，服务层组织鉴权与事务，数据访问层执行受授权范围约束的查询。后台任务直接读取持久化任务表，不引入 Redis、消息队列或 WebSocket。

3.2. 会话与数据表示

身份认证采用持久化的不透明令牌，随机源生成 32 字节令牌，数据库只保存 SHA-256 摘要。Web 使用名为 sid、Path 为根路径、不设 Domain 的 Cookie，生产启用 HttpOnly、Secure、SameSite=Lax；小程序仅通过 Authorization 请求头携带 Bearer 令牌。登录时轮换会话，退出撤销当前会话，改密、重置密码及停用撤销全部会话。每个令牌自创建起最多 7 天，空闲 30 分钟失效；鉴权成功后更新 last_seen_at，绝对到期不随访问延长。

接口前缀为 /api/v1，JSON 字段采用小驼峰。主键、关联键和版本均以十进制字符串传输，避免 JavaScript 整数精度损失。金额采用固定两位小数的字符串，如“3000.00”；数量采用最多三位小数的字符串，禁止指数、千位分隔符和隐式舍入。时间戳为带 Z 的 UTC ISO 8601 字符串，业务日期为 YYYY-MM-DD，北京时间仅用于界面与业务日期换算。自定义字段的数值也按对应类型传输，不猜测文本金额。

契约	字段与结果
列表	输入 page、pageSize，默认 1 和 20，上限 100；返回 items、total、page、pageSize。筛选字段只接受 type、status、submittedFrom、submittedTo、keyword 及有权使用的 departmentId
详情	返回 id、applicationNo、type、status、rowVersion、正文、amount、currentNode、history 和 allowedActions。草稿编号/提交时间/正式金额可为空，已提交正文只读
成功	读取返回 200；创建返回 201 及资源 ID；变更返回 200 及新版本；删除草稿返回 204。业务结果包装为 data，附 requestId 与 serverTime，文件流不使用 JSON 包装
错误	返回 code、message、fieldErrors、requestId、retryable。fieldErrors 为 path 与 message 列表，路径可定位 payload.items[0].unitPrice。不得返回 SQL、堆栈或服务器路径
写入并发	已存在申请及草稿写入收 expectedVersion，创建草稿不收该字段；管理写入收 expectedConfigVersion，编辑既有对象另收 expectedVersion。申请写入、附件绑定/解绑及节点交接以 Idempotency-Key 头携带 UUID 请求键；普通管理写只提供版本保护

参数错误 400；未认证或会话失效 401；有资源阅读权但动作被禁止 403；不可见或不存在资源均 404；版本、状态、同键异内容及唯一性竞争返回 409；请求体或文件超限 413；限流 429 并给 Retry-After；数据库暂不可用或事务重试耗尽 503。幂等结果只保存已提交成功的业务变更，校验失败可修正后使用新键。POST 创建草稿也纳入请求键，防止响应丢失后生成两个草稿。

关键词只匹配申请编号和标题，最长 100 字符，将百分号和下划线当普通字符转义；SQL 参数化，不接受任意字段排序。已提交列表按 submitted_at 与 id 倒序；本人草稿按 updated_at，待办按 activated_at，已办按本人最近处理时间，均以 ID 消除同时间并列。列表先按权限过滤再计数与分页；实时数据变化可使跨页结果变化，分页不是历史快照。已办按本人有效批准或驳回记录按单去重，提交、撤回不计入审批已办。

3.3. 资源接口与业务载荷

路径中的 id 均为服务端资源 ID。表中的字段为请求白名单；当前用户、确认部门、正式合计、状态和实际审批人不接受客户端赋值。表单保存与附件绑定分别提交，并返回新版本，客户端收到后才能继续下一次写入。

身份接口	输入与返回
GET /auth/csrf	取得短期预认证 CSRF 上下文，不产生登录会话；Cookie 认证入口写请求须携带匹配令牌及可信 Origin
POST /auth/register；POST /native-auth/register	username、name、email、password、requestedDepartmentId；返回 userId 与 PENDING。注册不接受角色字段，原生入口不创建 Cookie
POST /auth/login；POST /native-auth/login	username、password；返回账户状态、mustChangePassword 及权限摘要。前者只设置 Web Cookie，后者只在响应体返回小程序令牌

身份接口	输入与返回
POST /profile/confirmation-request	仅已拒绝账户；requestedDepartmentId、expectedVersion、expectedConfigVersion；锁配置及本人账户后重验资料，清除拒绝原因并回 PENDING，返回两类新版本
POST /auth/logout	撤销当前会话，重复退出不报业务错误；不通过 GET 改变登录状态
GET /profile；PATCH /profile	读取个人资料；已拒绝账户另获重申所需 configVersion。修改 name、email 携带 expectedVersion 并返回新 rowVersion，不能携带角色或确认部门变更
POST /profile/password	oldPassword、newPassword；修改后撤销全部会话并要求重新登录。强制改密账户仅可访问本接口、资料状态及退出
GET /departments	注册时仅返回启用部门的 ID 和名称；不暴露成员、负责人邮箱或内部授权

申请及动作接口	输入与返回
POST /applications	type、templateVersionId 或 sourceApplicationId；创建本人草稿，返回 id、rowVersion 及可编辑 payload，编号为空
GET /applications；GET /applications/id	受权限过滤的列表及详情；view 可为 mine 或 authorized。草稿仅本人可见，不接受伪造 applicantId 扩展范围
PUT /applications/id/draft	expectedVersion、title、remark、payload；只保存草稿。服务端校验已有字段格式与行键，返回新版本和绑定摘要
DELETE /applications/id	expectedVersion；仅删除本人草稿。正文、绑定删除及清理任务入队同事务；已提交不提供删除入口
POST /applications/id/submit	expectedVersion；提交已保存草稿，服务端重算、解析和冻结，返回编号、金额、当前节点及新版本
POST /applications/id/withdraw	expectedVersion、可选 opinion；仅申请人处理审批中申请，取消待办并返回终态及新版本
GET /tasks；GET /handled	本人当前有效待办；本人有效批准/驳回的已办按单列表。不接受其他 userId 查询替代本人
POST /tasks/id/approve；POST /tasks/id/reject	expectedVersion 指申请版本，opinion 批准可空、驳回必填；返回申请状态、新版本及当前节点，无权后节点不可处理
POST /admin/tasks/id/reassign	expectedConfigVersion、expectedVersion、newApproverId、reason；显式交接，校验角色、部门与非自审，返回两类新版本

payload 类型	可编辑字段与行关系
采购	reason、expectedDate、project、budget、freightAmount、otherAmount、otherReason、items、quotes、selectedQuoteKey、selectionReason、singleSourceReason、nonLowestReason。items 含 clientKey、name、specification、quantity、unit、unitPrice；quotes 含 clientKey、supplier、quoteDate、total、sourceType、purchaseUrl、basisText
差旅	origin、destination、startAt、endAt、purpose、companions、transport、budget；天数只由服务端计算
报销	description、relatedApplicationId、independentReason、items；每行含 clientKey、type、expenseDate、purpose、amount、noReceipt、noReceiptReason。票号与文件保存在绑定中，不随费用行覆盖
自定义	模板版本及 formValues；字段、类型与校验来自该发布版本，系统身份字段不可成为用户可写的表单字段

每条草稿费用、采购明细和报价都有本单唯一且保存后不变的 clientKey。草稿绑定以该键定位费用或报价，正式行 ID 在提交时产生；selectedQuoteKey 须命中本单报价。

删除草稿行同时解绑该行附件并返回处理结果，不能留下指向不存在行的文件。提交响应返回正式行 ID，已提交查询不再用草稿键替代正式外键。

附件、通知与统计接口	输入与返回
POST /files	multipart 上传，返回 fileId、原名、类型、大小和摘要；文件暂未绑定，不因知道 fileId 就获得阅读权。重传可产生临时对象，绑定仍按摘要去重
POST /applications/id/bindings	expectedVersion、fileId、purpose、draftTargetKey 或 fieldKey、可选 receiptNumber；仅本人草稿，返回 bindingId 和新版本
DELETE /applications/id/bindings/bid	expectedVersion；仅草稿解绑，校验 bid 属于本单，返回新版本；无引用对象异步清理
GET /files/id/preview；GET /files/id/download	读取已绑定文件必须给 applicationId 并校验有效绑定及当前单据阅读权；未绑定临时文件仅上传者可读
GET /notifications；GET /notification-sync	本人分页通知及打开时的 readBoundary；同步收可选 inboxRevision，返回 inboxRevision、notificationChanged、未读数、pendingCount、taskDigest 和 serverTime，不返回其他用户摘要
POST /notifications/id/read；POST /notifications/read-all	单条幂等设已读；全部已读收用户绑定的 readBoundary，仅作用于该打开边界内消息，返回新摘要
GET /statistics	scope 为 PERSONAL、DEPARTMENT 或 ENTERPRISE，输入对应部门与提交区间；返回数量、分类型金额、口径说明及可否钻取

管理及配置接口	输入与返回
GET /admin/config	返回 configVersion、有效 policyVersionId 及允许的配置值；不返回 SMTP 密钥
GET /admin/users；GET /admin/departments	管理分页与对象 rowVersion、负责人及引用摘要；不能用管理列表替代业务正文接口
POST /admin/users/id/confirm；/reject	expectedConfigVersion、expectedVersion；确认收 departmentId，拒绝收 reason，返回账户状态与两类新版本
PATCH /admin/users/id；PUT /admin/users/id/roles	对象状态或角色集合、变更原因与两类预期版本；重置密码另用 POST /admin/users/id/reset-password，临时密码不写日志
POST /admin/departments；PATCH /admin/departments/id	名称、启用状态或负责人、原因与预期版本；先完成受影响节点交接，禁止隐式批量改派
GET /admin/grants；POST /admin/grants；POST /admin/grants/id/revoke	userId、ability、scope、departmentId、validFrom、validUntil、reason 及 expectedConfigVersion；不原地覆盖授权历史
GET /templates；GET /templates/id/versions/vid	员工仅获得适用且启用模板的发布定义；已有草稿可读取引用的旧发布版本，停用后仍可读取本人旧单快照
POST /admin/templates；PUT /admin/templates/id/draft	模板元信息、适用部门、字段及顺序节点定义和预期版本；响应配置与对象新版本，不返回执行实现
POST /admin/templates/id/publish；/enable；/disable	预期版本及原因；发布返回不可变 versionId，启停只改变后续可提交性
POST /admin/policy-versions；POST /admin/policy-versions/id/publish	阈值、主备、部门备选、时长及附件限制；先保存候选再发布，expectedConfigVersion 保护生效指针切换
GET /admin/audit-records；GET /admin/mail-deliveries	管理分页读取审计、邮件状态及脱敏错误；无修改审计、代用户标已读或直接改申请终态接口

短文本、标题和正文分别限定 80、200、2000 字符，用户名与邮箱采用账户规则；说明类字段用正文上限，备注也不超过 2000 字符。采购明细最多 100 行、报价最多 10 家、报销明细最多 50 行；至少支持两行采购与三行报销，不强迫用户凑行。JSON 请求体上限 1 MiB。限制在前后端一致展示，附件仍遵循独立的文件容量与数量约束。

3.4. 安全参数与失败交互

密码采用 Spring Security 的 Argon2id 编码器，显式配置 19,456 KiB 内存、2 次迭代、并行度 1、16 字节随机盐和 32 字节摘要，声明所需加密提供者依赖。密码按 Unicode 字符计 8—64 位，不裁剪、不规范化、不静默截断；日志不记录密码或哈希。用户名仅限既定 ASCII 字符，存小写规范值并用 utf8mb4_bin 判重；邮箱去首尾空格、将 ASCII 邮箱整体转小写，不做去点或加号别名合并，姓名保留显示值。

Web 登录前由 GET /auth/csrf 建立短期预认证 CSRF 上下文；Web 登录、注册、退出及所有 Cookie 写请求验证服务端关联的 CSRF 令牌与 Origin 白名单，登录成功后轮换上下文。小程序首次登录或注册使用 /native-auth 独立匿名入口，不接受任何 Cookie、不读取 Web 会话、不设置 Cookie；登录仅凭账号密码验证并在响应体返回令牌，因此无需已有 Bearer 令牌或 Web 预认证上下文。后续仅请求头携带有效会话令牌、且未携带 Cookie 的请求可免 CSRF；两种凭据并存直接拒绝，不按 User-Agent 或自报 clientType 绕过。CORS 只允许部署清单中的确切源，不使用带凭据的通配符；Web 与 API 生产同源。

控制点	设计参数与失败行为
登录与注册	单 IP 每分钟最多 20 次登录、10 次注册；同规范化账户 15 分钟内最多 5 次失败登录，触发 429 及剩余等待时间。不存在账户也执行同类哈希验证并返回统一凭据错误，避免用接口枚举账号
文件与日志	上传每账户每分钟最多 30 次；Nginx 与后端共同限制体积。存储卷不可直接访问，预览禁用活动脚本，下载设 nosniff 和安全 Content-Disposition；原名不参与路径拼接
数据与页面	SQL 参数化、排序字段白名单；姓名、理由和自定义文本按纯文本转义，不接受富文本 HTML。页面使用同源 CSP，禁止对象嵌入及第三方框架嵌套；预览使用受限组件
密钥与追踪	会话令牌、CSRF、SMTP 密码及临时密码不入日志。每请求生成追踪号；业务错误、上传失败、鉴权拒绝记录脱敏事件，不记录票据正文或完整表单

限流窗口与计数保存在 MySQL 的 rate_limit_bucket，以散列后的账户或来源标识作键，原子计数并定时清理；不引入 Redis。反向代理只信任自身写入的客户端地址头，不接受公网伪造来源。会话、摘要和详情响应设 Cache-Control: no-store，不把敏感数据留在共享缓存。

错误不仅用颜色表示，字段同时显示文字与定位。桌面键盘可到达主要操作，弹窗打开后圈定焦点、关闭后归还触发按钮。图表附数量与金额摘要；移动系统字体放大到 130% 时不截断关键按钮。网络失败保留用户输入，轮询退避至最长 60 秒，恢复前台立即刷新；正常网络下前台变化 15 秒内可见作为验收目标。

4 数据库设计

4.1. 实体关系

申请主表保存归属、状态、金额和版本，三类固定业务采用独立扩展表与明细表。自定义表单以 JSON 保存字段值并绑定模板版本。草稿允许不完整，独立保存工作数据，提交时写入正式业务表。

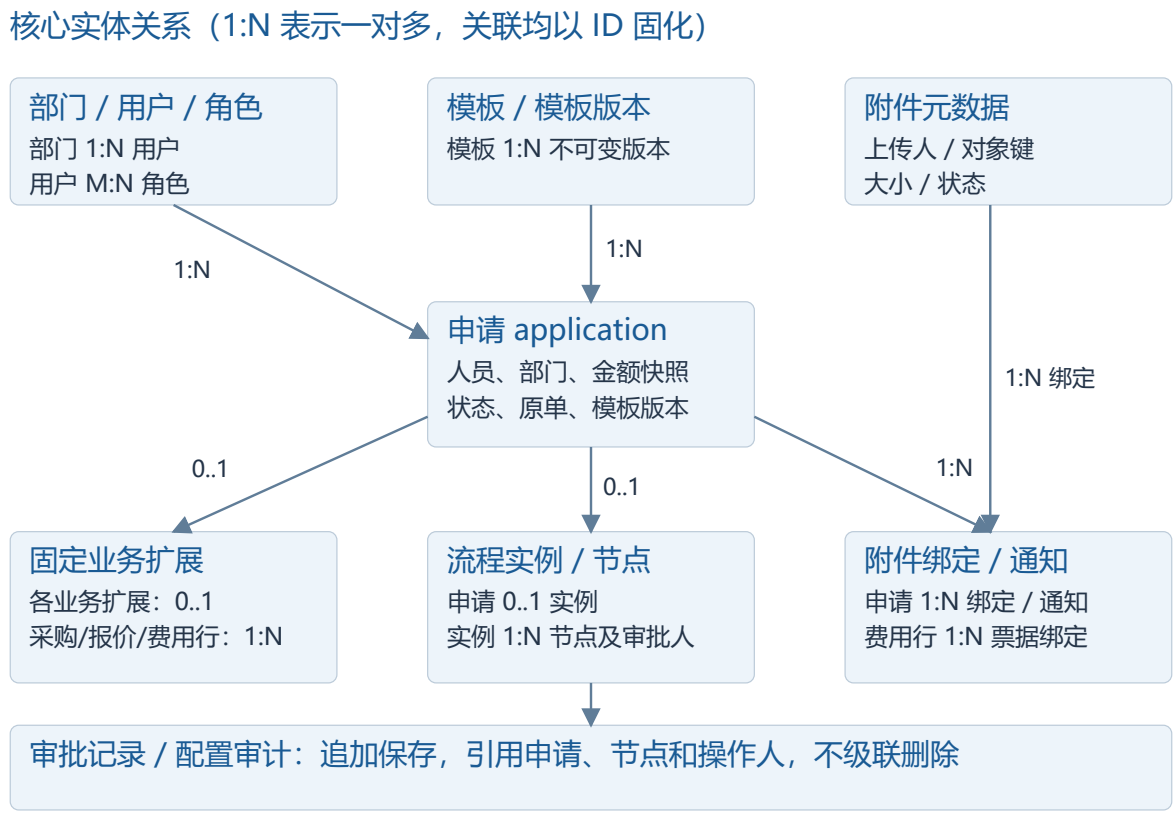


图 2　申请关联业务正文、流程实例、票据绑定和追加历史

申请到业务扩展、流程实例均为 0..1，提交后恰有一种匹配类型的正文和一个实例。主键采用 BIGINT，接口以字符串传输；时间以 UTC 保存、北京时间展示，业务日期采用 DATE。

4.2. 表结构

PK 为主键，FK 为外键，UQ 为唯一约束。创建时间、操作人及身份快照由服务端写入。组织、授权、模板与配置均保存变更版本。

表 / 主键	关键字段与约束
department / id	name VARCHAR(80) UQ；enabled；manager_user_id FK→user；row_version。负责人可缺，但依赖该规则的申请不能提交
user / id	username VARCHAR(64) UQ；email VARCHAR(254) UQ；password_hash VARCHAR(255)；name VARCHAR(80)；requested_department_id FK；department_id FK 可空；status；rejection_reason 可空；must_change_password；row_version

表 / 主键	关键字段与约束
role、user_role	role.code UQ；user_role 以(user_id, role_id)为联合 PK
data_grant / id	user_id；ability：READ_BODY 或 STATISTICS；scope：DEPARTMENT 或 ENTERPRISE；department_id；valid_from、valid_until、revoked_at；授予人及原因。部门范围必须指定部门，企业范围部门为空
auth_session / id	user_id FK；token_hash BINARY(32) UQ；created_at；last_seen_at；absolute_expires_at；revoked_at 可空；client_type。令牌原文不落库
system_config / id	唯一行 id=1；active_policy_id FK，可为空直至首次发布；row_version。全管理域的配置版本，不随普通资料修改递增
flow_template / id	code UQ；name；description；enabled；current_version_id；row_version。适用部门由 template_department 关联表保存
template_department	template_id FK→flow_template；department_id FK→department；两者为联合 PK。启用模板至少关联一个适用部门
template_version / id	template_id FK；version_no；field_schema、node_schema、rule_schema JSON；DRAFT 或 PUBLISHED；published_at；UQ(template_id, version_no)。发布内容不可改
policy_version / id	version_no UQ；采购/报销/差旅阈值；财务与企业负责人主备 user_id；部门备选人员映射；timeout_hours；附件限制；published_at。system_config 单行记录 active_policy_id 与 row_version，发布版本不可改
application / id	application_no VARCHAR(40) UQ；type；title；remark；applicant_id；dept_id；身份名称快照；status；amount DECIMAL(14,2)；row_version；template_version_id（固定业务为空，自定义申请必填）；source_application_id；submitted_at
application_draft / application_id	FK→application；payload JSON；draft_schema_version；updated_at。提交成功后删除工作副本，正式正文冻结

表 / 主键	业务字段与关联
purchase / application_id	reason；expected_date；project；budget；freight_amount；other_amount；other_reason；selected_quote_id；single_source_reason；selection_reason；non_lowest_reason。金额均为 DECIMAL(14,2)
purchase_item / id	application_id FK；line_no；name；specification；quantity DECIMAL(12,3)；unit；unit_price、line_amount DECIMAL(14,2)。UQ(application_id, line_no)
supplier_quote / id	application_id FK；supplier；quote_date；total DECIMAL(14,2)；source_type；purchase_url；basis_text。拟选报价须属于本单
travel / application_id	origin；destination；start_at；end_at；purpose；companions；transport；budget DECIMAL(14,2)；natural_days
reimbursement / application_id	description；related_application_id FK，可空；independent_reason
expense_item / id	application_id FK；line_no；type；expense_date；purpose；amount DECIMAL(14,2)；no_receipt；no_receipt_reason。票据号不放在费用行
custom_form / application_id	template_version_id FK；form_values JSON。字段、类型和值符合引用版本
flow_instance / id	application_id FK UQ；template_version_id（固定业务为空，自定义必填）；policy_version_id 必填；form_snapshot、rule_snapshot JSON；current_order；解析时间。自定义流程也从配置版本冻结附件限制与超时时长

表 / 主键	业务字段与关联
instance_node / id	instance_id FK；order_no；node_name；approver_id FK；approver_name_snapshot；rule_snapshot；status；activated_at；due_at；assignment_version；handled_at。UQ(instance_id, order_no)
approval_record / id	application_id、instance_id；node_id 提交时为空、撤回时记当前节点；申请版本；actor_id 及姓名快照；action；opinion；result；created_at；request_key。提交、批准、驳回、撤回、改派均追加记录

表 / 主键	附件、通知和事务支撑
file_object / id	owner_id FK；storage_key UQ；original_name；media_type；byte_size；sha256；status；created_at。原名只供展示
file_binding / id	application_id、file_id FK；purpose；draft_target_key VARCHAR(64)、field_key VARCHAR(64)、expense_item_id、quote_id 均按用途可空；receipt_number VARCHAR(80)可空；receipt_sha256 BINARY(32)仅票据填写。UQ(application_id, file_id)及 UQ(application_id, receipt_sha256)
notification / id	recipient_id FK；application_id FK；delivery_seq；event_key；type；summary；created_at；read_at 可空。UQ(recipient_id, event_key)与 UQ(recipient_id, delivery_seq)
inbox_state / user_id	PK 且 FK→user；last_delivery_seq、revision 默认 0。注册同事务创建，所有通知及已读更新先锁该用户行
rate_limit_bucket	bucket_key BINARY(32)、window_start DATETIME(6)联合 PK；counter INT UNSIGNED 默认 0；expires_at。散列标识与原子窗口计数，不保存原密码或令牌
reminder_record / id	node_id FK；assignment_version；trigger_type；recipient_id；due_at_snapshot；created_at。UQ(node_id, assignment_version, trigger_type)，每次分配仅一次超时催办
request_record / id	actor_id；action；request_key；payload_hash；target_id；result_code；result_summary；created_at。UQ(actor_id, action, request_key)，成功结果与业务同事务保存
mail_delivery / id	notification_id FK UQ；recipient_email_snapshot；status；attempts；next_retry_at；lease_until；last_error。与通知同事务创建，租约到期可重新领取
audit_record / id	actor_id；target_type、target_id；action；脱敏前后值；reason；request_id；created_at。记录角色、部门、授权、模板及配置变更
file_cleanup / id	file_id 或 storage_key；status；attempts；next_retry_at。解绑提交后执行物理清理

同一费用行可对应多条票据绑定，分别保存号码、原文件名和上传信息；票号不作为真实性判据，也不代替同单摘要去重。相同文件对象可被合法复制到新单，但每个绑定保留本单票号及用途，不改写原绑定。

4.3. 字段类型与关联约束

普通实体 ID 为 BIGINT UNSIGNED 自增主键；外键采用相同类型。时间戳为 DATETIME(6)，数据库连接与应用统一 UTC；创建和更新时间由服务端显式赋值，业务日期为 DATE。row_version、assignment_version、delivery_seq 和 revision 采用 BIGINT UNSIGNED，版本从 1 开始、计数从 0 开始，递增检查溢出。布尔字段为 TINYINT 并加 0/1 检查，JSON 字段由服务层按固定结构校验，不把任意 JSON 当可信规则执行。

字段组	类型、空值及默认值	完整性约束
账户与组织	用户名 VARCHAR(64)、邮箱 VARCHAR(254)、姓名 VARCHAR(80)非空；status VARCHAR(16)默认 PENDING；must_change_password 默认 0	status 仅 PENDING、ACTIVE、REJECTED、DISABLED；已确认账户 department_id 非空；拒绝原因非空；用户名和邮箱规范值用二进制排序判重
申请主表	type VARCHAR(16)、status VARCHAR(16)非空；status 默认 DRAFT；标题 VARCHAR(200)默认空串；备注 VARCHAR(2000)默认空串；编号、金额、submitted_at 草稿可空	type 仅 PURCHASE、TRAVEL、REIMBURSEMENT、CUSTOM；status 仅 DRAFT、IN_REVIEW、APPROVED、REJECTED、WITHDRAWN；提交时标题及身份快照必填
金额与明细	金额 DECIMAL(14,2)；数量 DECIMAL(12,3)；line_no INT UNSIGNED 非空；费用日期 DATE 非空	明细主键另加 UQ(application_id, id)，行号加 UQ(application_id, line_no)；费用金额大于 0，预算与运费可为 0
节点与记录	order_no INT UNSIGNED；status VARCHAR(16)；assignment_version 默认 1；activated_at、due_at、handled_at 按状态可空；意见 VARCHAR(2000)	节点状态 WAITING、PENDING、APPROVED、REJECTED、CANCELLED；当前节点激活及截止时间非空；驳回意见非空；每实例当前节点唯一性由持申请锁的服务逻辑维护
通知与请求	event_key VARCHAR(200)、摘要 VARCHAR(200)、delivery_seq 非空；request_key CHAR(36)、payload_hash BINARY(32)；成功结果 JSON 非空	事件键采用二进制比较；请求唯一键包含操作人与动作；请求结果保留至对应业务归档，不按短期缓存随意删除
授权与版本	ability、scope VARCHAR(16)；valid_from、valid_until 非空；revoked_at 可空；发布定义 JSON 非空	期限结束严格晚于开始，当前时间落在左闭右开区间且未撤销才有效；发布状态与 published_at 一致；发布内容只追加

除明确允许空值的列外，业务必填字段在正式表均设 NOT NULL，文本选填用空串，未知的关联或时间用 NULL，不以 0 代替缺失外键。扩展表主键同时外键指向 application；实例、日志、绑定、通知的申请及人员引用均设外键。关联源申请、模板版本和配置版本使用 RESTRICT，用户与部门停用而不级联删除历史。department.manager_user_id 与 user.department_id 构成可空循环，初始化先建部门、再建用户、最后任命负责人。

file_binding 的 purpose 限定为 GENERAL、QUOTE_EVIDENCE、EXPENSE_RECEIPT、CUSTOM_FIELD。草稿费用票据或报价依据恰有 draft_target_key 而无正式行外键，键须存在于本单对应数组且唯一；通用附件不填目标键，自定义附件使用发布定义中的 field_key。提交在申请锁内建立正式行、用服务端映射填入 expense_item_id 或 quote_id、清除 draft_target_key，自定义 field_key 保留；随后删除草稿 JSON，任一步失败均回滚。正式费用、报价与绑定用(application_id, id)复合外键保证属于同单；用途检查防止同时指向费用与报价。

采购扩展先以空 selected_quote_id 插入，再插本单报价并回填选择；提交事务结束前该字段必须非空，并用(application_id, selected_quote_id)指向本单报价的联合唯一键。草稿不在正式采购表占位。模板的 current_version_id 须属于本模板，custom_form 与 application 引用同一发布版本；跨表类型和发布状态在事务内复验。草稿删除显式解绑，正式历史引用均不级联清除。

4.4. 金额、索引与删除策略

金额使用 Java BigDecimal 计算，不用浮点数决定路径。采购单行按数量乘单价、HALF_UP 舍入到分后求和，再加非负运费和其他费用；报销以有效费用行求和。输入金额最多两位小数，每项输入及合计不超过 10,000,000.00 元，数量大于 0 且不超过 999,999,999.999、最多三位小数；乘积先用 BigDecimal 计算再检查行金额上限，超范围或超精度拒绝，不静默截断。application.amount 在提交时分别保存采购整单总额、差旅预算或报销合计，阈值判断与统计读取同一冻结值；自定义申请该字段为空。客户端合计仅展示。

草稿编号和提交时间为空，提交时按“业务前缀-北京时间日期-申请 ID 补足 20 位”生成编号，例如前缀 CG、CL、BX、ZD 分别对应四类业务。申请 ID 在创建草稿时由数据库生成，提交锁内只赋一次编号；日期为首次成功提交日，不要求按日连续，允许删除草稿和事务回滚导致断号。主表唯一约束防止重复，不用查询最大值加一。选商、费用与附件使用跨表归属约束并在事务内复验，禁止将其他申请的报价或费用 ID 写入本单。

访问路径	主要索引
本人 / 部门申请	application(applicant_id, submitted_at, id)；application(dept_id, status, submitted_at, id)
待办 / 已办	instance_node(approver_id, status, activated_at, id)；approval_record(actor_id, action, created_at, application_id)；approval_record(application_id, created_at, id)
通知 / 邮件	notification(recipient_id, read_at, delivery_seq)；notification(recipient_id, delivery_seq)；mail_delivery(status, next_retry_at, id)
催办 / 票据	instance_node(status, due_at, id)；file_binding(receipt_sha256, application_id)；提醒记录分配版本唯一键
审计 / 清理	audit_record(actor_id, created_at, id)；audit_record(target_type, target_id, created_at, id)；file_cleanup(status, next_retry_at)

用户、部门、模板采用停用，保留被引用对象。已提交申请、实例、审批与审计记录限制删除。业务数据库账户无审批日志和审计表的更新、删除权限，部署迁移账号另设。删除本人草稿可删除工作数据与文件绑定，无引用文件进入清理队列。查询计划以最终 SQL 验证，已办先按操作人过滤和申请分组，再联查授权正文，避免重复行破坏分页。

5 审批流程与事务

5.1. 提交与人员快照

提交重验账户、当前确认部门、业务字段、票据归属、金额及启用模板，再解析完整路径。申请部门及身份快照在提交时从当前资料写入，不沿用草稿创建时的旧部门；调部门后旧模板不再适用则拒绝提交并保留输入。每个节点确定一名启用用户。负责人缺失、配置不完整、候选停用或自审无备选时拒绝提交，保留草稿并给出具体原因。

固定流程为“部门负责人→财务→条件企业负责人”。采购、报销金额大于 5,000 元，差旅预算大于 20,000 元时增加企业负责人；等于阈值不增加。阈值、人员与超时时长来自同一已发布配置版本。

节点	人员解析规则
部门负责人	主选为申请人确认部门的负责人；主选为申请人时使用该部门配置的备选。两者都须是本部门启用用户，备选与主选不同
财务	管理端指定一名主选及一名备选，二者均具有财务审批角色；主选为申请人时选择备选。不会在多个财务账户间随机选择
企业负责人	管理端指定一名主选及一名备选，二者均具有企业负责人角色；主选为申请人时选择备选

发布时验证人员角色、部门与启用状态；提交时再次验证，不以备选静默掩盖停用或失效配置。同一人可以承担不同节点，但逐节点分别处理且均不得为申请人。实际人员、选用主备的原因、条件结果和金额口径一并冻结，后续组织或阈值变更不改写旧实例。提交事务检查配置版本，遇到并发发布重新读取并校验，不混用两版规则。

5.2. 模板版本与重提

模板含名称、说明、适用部门、版本和启用状态；字段支持单行文本、多行文本、数字或金额、日期、单选及附件，配置名称、必填与校验。每个模板至少两个可调序的顺序节点，审批人规则包括指定用户及申请人部门负责人。

发布校验字段标识唯一、条件引用有效、节点完整、审批人规则有效且无循环。模板启用时，已有草稿可引用已发布旧版；停用阻止新提交，已提交实例继续执行快照。已发布定义不可原地修改，只能派生新版本。设备借用作为第四类流程，由管理页配置后在员工端直接填写，不增加固定业务页面。

换版采用复制填写，申请人按新字段确认，不自动迁移未知字段。驳回或撤回重提生成新申请并记录原单 ID；原历史与附件绑定保持不变，复制附件仍校验访问权与状态。自定义表单与流程模块按课程约束由本人独立编码，不使用 AI 辅助编程；本设计仅规定需求、界面与验收边界。

5.3. 状态与节点

申请状态为草稿、审批中、已通过、已驳回和已撤回。草稿可编辑、删除；审批中仅当前节点可处理，申请人可撤回。终态禁止修改与再次审批。

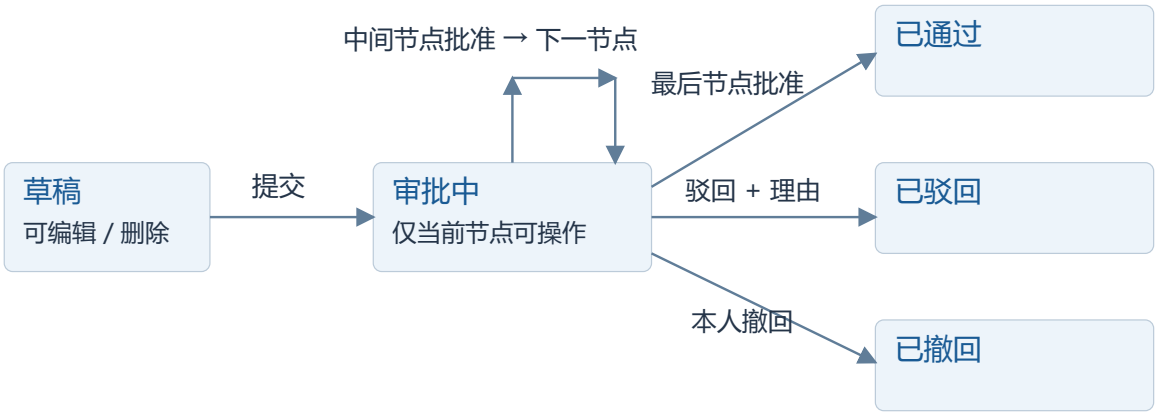


图 3　中间批准推进节点，驳回与撤回保留历史并结束本次实例

中间节点批准后激活下一节点，申请仍为审批中，版本加一；最后节点批准后转已通过。节点区分等待、当前待办、已通过、已驳回和已取消，每个实例最多一个当前待办。驳回必填理由并取消剩余节点；撤回取消未完成节点。

当前节点激活时保存激活时间和截止时间，等待节点尚不计时。管理员显式交接时追加变更记录并递增分配版本，重新计算截止时间；原快照与旧催办历史保留，不把组织配置变更当作自动改派。

5.4. 并发与请求重试

所有申请写请求携带预期版本和请求键。先验证当前身份及账户限制；指纹由 HTTP 方法、规范化资源路径与目标 ID、动作和规范化请求正文共同计算，不只散列正文。幂等记录以操作人、动作和请求键定位，再比对目标与完整指纹；同键异目标或异内容返回 409。创建草稿可在无目标 ID 时按创建动作重放；删除草稿成功后即使目标已不存在，也只向原操作人返回同键同指纹的 204。其他已存在资源仍先校验当前访问权，命中成功结果才返回原响应，旧预期版本不再触发冲突。

新请求按动作取得所需锁，在事务内锁定申请后、检查版本前再次读取同键结果。节点交接取得配置锁并重验操作者权限后，先查成功记录，再检查两类预期版本；普通管理写入不承诺原键重放，冲突后需刷新并再次确认。创建草稿尚无申请锁，依靠请求唯一键与草稿同事务保存；唯一键冲突回滚本次新草稿后读取已成功的结果。request_record.target_id 为业务定位值，不设阻止草稿删除的外键。

已有同键同指纹结果则返回，否则校验版本、状态、节点和操作人，再更新业务并递增版本。业务正文、节点、日志、站内通知、邮件任务和请求结果同事务提交。同键并发由唯一约束兜底，冲突方在首个事务结束后读取结果；事务失败全部回滚。

场景	处理结果
双浏览器批准	同版本仅一次成功，另一请求 409；不重复日志或通知
批准与撤回竞争	同版本仅一方成功，中间节点批准同样递增版本
成功响应丢失	同键同内容返回原结果；不同键携带旧版本返回 409

场景	处理结果
事务中断	业务和附属记录回滚；事务内不先删除物理文件
人员交接	锁定申请、检查任务状态并更新分配版本；追加原人、新人及原因，禁止自审

锁顺序统一为 system_config→按 ID 升序的 application→按 ID 升序的 file_object→按 user_id 升序的 inbox_state；不需要的层可跳过。一次流转先汇总全部通知接收人，再按序锁收件箱，不按业务发送顺序逐个加锁。注册即创建收件箱行，修复缺失行也按用户 ID 排序。普通批准、驳回、撤回、催办、清理和邮件只使用冻结配置，不得持后序锁再申请配置锁。提交和管理交接先取配置锁再取申请锁；资料与会话涉及用户行时统一 user→auth_session，不反向获取配置锁。

死锁或数据库暂时不可用返回可重试错误，客户端复用原请求键。通知与邮件仅在事务提交后展示或发送；进程中断后从数据库任务表恢复。

6 附件、提醒与统计

6.1. 附件与重复票据预警

支持 JPEG、PNG、PDF，默认单文件 10 MiB、每申请 20 个、合计 100 MiB；按有效绑定累计。上传验证扩展名、媒体类型和文件头，存储键由服务端随机生成。管理端只能在部署硬上限内收紧限制；申请提交冻结本次附件限制，收紧配置不删除旧单文件。

上传先保存临时元数据，绑定草稿检查所有权及状态。提交后冻结绑定，禁止替换正文附件。预览、缩略信息和下载均通过业务鉴权，私有卷不直接对外开放；图片与 PDF 受限预览，下载设置内容类型及文件名。

同单票据按文件 ID 或服务端计算的 SHA-256 摘要去重，重传相同字节也不能重复绑定。跨单预警匹配其他审批中或已通过报销单的票据摘要，排除本单、草稿、驳回及撤回单。相同字节只能证明文件相同，不证明重复报销；重拍、裁剪或转格式不在检测范围内。

草稿选票时预检，提交和财务打开详情时重新检查；并发提交后，以财务复查提示新出现的相同票据。发现相同摘要以黄色提示，不阻断合法提交，不自动改变审批结论。有原单阅读权才显示原单编号和链接，否则仅显示“存在相同票据文件”，不返回他人的姓名、金额、文件名或下载地址。财务可在审批意见中记录核实结论。

复制草稿可共享文件对象，解绑只影响本单。绑定与清理资格判断锁定同一文件记录；无引用对象先标记清理中并禁止新绑定，删除前再核验。清理失败重试，超过 24 小时的未绑定临时文件进入清理队列，任何有效引用均阻止删除。

6.2. 站内通知与邮件

新待办通知当前审批人；通过、驳回、撤回通知申请人，撤回另通知被取消的当前待办人员。流转事件键由申请、流转版本和类型构成，按接收人去重。未读数、列表和已读操作限定本人；失效通知保留，跳转时重新鉴权。

Web 与小程序前台每 10 秒读取权威轻摘要，不采用事件强增量协议。GET /notification-sync 在同一 InnoDB 可重复读只读事务中读取收件箱 revision、last_delivery_seq、未读数及当前待办摘要；revision 与客户端值不同只表示通知页失

效，需要重读当前页，不表示逐条事件序列。接口每次重新查询当前有效任务，将任务 ID、分配版本和申请版本按任务 ID 排序后计算 taskDigest，同时返回 pendingCount；即使通知 revision 不变、待办数量不变，也比较摘要并刷新待办页，不对整个响应返回 304。打开的详情独立轮询申请版本。

通知创建先锁接收人的 inbox_state，检查事件唯一键，只有新通知才分配下一 delivery_seq、递增 revision 并保存；已读变更也在该锁内更新 revision。所有接收人按用户 ID 升序锁定，事务提交前锁不释放，因此本用户通知顺序不靠全局自增 ID 推断。通知页按 delivery_seq 倒序分页，新到通知可使页位置变化，旧通知始终可从持久通知中心检索；不承诺积压期间每条消息都弹提示。

打开通知页时，用同一只读快照的 last_delivery_seq 生成 readBoundary，签名绑定用户 ID、该边界 B 和 15 分钟到期时间。全部已读从会话取得当前用户、验证签名并锁该收件箱，只更新本人 delivery_seq 不超过 B 且未读的通知，实际有变更才递增 revision，与更新同事务提交。B 可重复幂等使用，不要求当前 revision 仍等于发放边界时的值；随后到达的消息序号大于 B，不会被误标。过期边界返回 409 并要求刷新后确认，不静默扩大已读范围。

恢复前台或网络后立即重读摘要与当前页；通知变化刷新未读数和通知列表，待办摘要变化刷新任务页。正常网络下变化 15 秒内可见作为目标，弱网退避不作同样时延承诺。失效条目与已取消任务只显示当前状态，不自动重放旧审批动作。

邮件任务与站内通知同事务创建，后台领取时设租约；发送后保存结果，进程中断租约到期重试。只包含编号、状态和登录入口，不附票据或正文。SMTP 凭据由环境注入，按至少一次语义投递，发送成功但响应丢失可能重复。重试间隔 1、5、30 分钟，持续失败保留状态和站内通知；站内业务不依赖 SMTP 成功。

支持平台为桌面浏览器和微信小程序；后台触达依赖账户邮箱及手机邮件客户端，不依赖小程序后台计时器或微信订阅消息。用户拒绝相机权限时可选已有文件，拒绝或关闭邮件客户端通知时不宣称系统能强制弹出提醒，站内结果仍可查。

6.3. 超时催办

默认当前节点激活 24 小时后到期，按连续自然小时计算；时长随实例规则冻结。定时任务每分钟扫描当前待办，锁定申请后复核节点、分配版本与截止时间，写入催办记录、站内通知和邮件任务。重复扫描或多实例执行由唯一约束去重，每次分配只发一次自动催办。

催办事件键采用节点 ID、分配版本和事件类型，与流转通知分开。批准、驳回、撤回或改派先成功时，扫描跳过旧分配；催办先成功而审批随后完成时，保留历史通知，但点击显示最新状态。到期扫描允许一分钟调度延迟。催办不向无权限主管抄送、不自动转办，也不计作已办或改变申请版本。

6.4. 统计口径

申请统计按提交时间选择北京时间左闭右开区间，查询转 UTC。部门归属取提交快照，访问范围取当前授权。状态分布反映查询时的当前状态，不做历史时点还原。草稿单列，不混入已提交数量。

视图	指标及筛选
个人工作台	本人已提交总数、审批中/通过/驳回/撤回数、草稿数、本人当前待办和超时待办；通过金额按采购、差旅、报销分列
部门 / 企业	各类申请数量柱状图、状态分布、各类型通过金额；部门负责人默认只看本部门，扩展范围须有相应显式授权，企业视图须显式授权
时间口径	申请指标按提交时间；草稿只显示当前总数；待办按当前有效节点显示存量，不受申请提交时间筛选，卡片标注“当前”

通过金额仅汇总当前已通过申请；采购预计金额、差旅预算、报销金额分别展示，不相加作实际支出。自定义申请默认只统计数量，不猜测任意数字字段的金额含义。点击图表携带筛选进入列表，列表再检查正文权限；只有统计权时仅显示聚合，不提供越权钻取。

7 界面设计

桌面导航为工作台、我的申请、我的待办、已办事项、通知、统计和个人资料，管理员另有管理入口。申请详情显示编号、申请人、部门、提交时间、当前审批人、票据和历史。原型表达字段布局及交互状态，不作为实现截图。

页面加载时显示骨架并禁用重复提交；空结果保留筛选条件和清空入口；错误显示原因及重试按钮。提交成功后显示编号和当前审批人，失败保留输入。删除草稿、撤回、停用和撤销授权均二次确认。字段错误定位至具体行；409 保留意见并刷新状态，不自动重放旧动作。

7.1. 账户与个人资料

登录与注册分开，注册不提供角色选择。待确认页显示申请部门、审核状态和拒绝原因；通过后重新读取权限进入工作台。个人资料将可编辑姓名、邮箱与只读部门、角色分区，改密独立确认。



图 4　账户原型：注册校验、待确认结果和个人资料修改

用户名或邮箱重复时在对应字段反馈；登录失败统一提示凭据错误，不暴露账号是否存在。管理员重置后的首次改密页不可跳过，会话过期返回登录并保留安全的页面入口，不保留密码。

7.2. 申请、待办与已办

列表统一提供类型、状态、时间、编号或标题关键词和分页。新建按钮列出三类固定业务及当前启用且适用本部门的模板。草稿展示更新时间，不显示虚构的提交编号；当前待办标记激活时间和超时。



图 5　工作台原型：筛选、申请与任务标签、列表反馈和分页

已办行显示本人最近动作、处理时间及申请现状，已办记录不因后续撤回而消失。提交人、部门等只读字段在服务端生成。列表条目点击后重新读取详情权限，失效条目提示原因并移出可操作集合。

7.3. 用户、部门与授权管理

管理入口侧栏固定显示用户、部门、角色与授权、流程配置、系统配置、审计。待确认列表显示申请资料与部门，确认弹窗要求管理员选择确认部门，拒绝弹窗必填原因。



图 6　组织管理原型：账户确认、负责人关系和独立数据授权

部门页维护名称和负责人；人员停用前展示受影响节点，完成交接后再停用。授权编辑区分别选择能力、范围、到期时间，企业范围以醒目标记确认。修改结果与审计流水号一起返回，不在管理页直接开放业务正文。

7.4. 固定流程配置与审计

配置页将金额阈值、固定节点主备人员、部门备选及超时时长放在同一版本草稿。发布前展示差异和校验结果，发布后只影响后续提交；已有实例中的人员变化走独立交接操作。



图 7　配置原型：固定节点人员、阈值及配置审计查询

附件页显示当前 10 MiB、20 个、100 MiB 限制及部署硬上限，输入只允许收紧。审计页按对象与操作人筛选，展示脱敏差异、原因和时间，不提供编辑、删除及回滚按钮；恢复旧配置也须发布新版本。

7.5. 采购申请

基本资料、明细和比价按填写顺序排列，右侧显示预算、含税明细合计、运费、其他费用与总额。报价差额和缺失依据在提交前集中显示。



图 8　采购原型：多行明细、供应商比价、整单费用和提交检查

选择单一来源后展开必填原因，未选最低价展开补充理由。外部链接只由浏览器打开，后端不抓取。草稿只校验已填字段格式，提交检查完整性、报价可比性、差额和审批人员。

7.6. 差旅与自定义申请

差旅在起止时间下即时显示自然日天数，结束早于开始时定位错误。同行人员采用文本录入，交通方式用预设选项加其他说明。获批详情提供关联报销入口，默认带入原单摘要。



图 9　业务原型：差旅日期与预算、设备借用字段和提交路径

设备借用表单按已发布版本显示设备名称、说明、数量、归还日期、用途和材料，页头显示模板名及版本。切换模板先确认是否放弃当前输入。金额或数字使用对应精度和范围提示，附件字段沿用统一上传与鉴权。

7.7. 报销与审批

每条费用独立管理票据及票号，支持展开多张票据、查看上传信息和移除草稿绑定。无票原因与跨单重复提示分开显示，前者是缺票例外，后者仅提示相同文件。



图 10　报销原型：费用与逐票信息、无票例外及当前审批操作

审批视图复用正文结构，集中显示合计、异常、关联单摘要和时间线。采购报价区醒目标记单一来源原因与非最低价理由。按钮由后端可操作集合控制，执行时再次鉴权；关联原单无阅读权时只显示本单冻结的必要摘要。驳回弹窗必须填写理由，409 保留意见，不重新发送旧动作。

7.8. 模板配置

采用表单式配置，不把顺序节点列表称为可视化流程编辑器。字段配置包括唯一标识、名称、类型、必填和校验；节点可新增、上移、下移，并选择指定用户或部门负责人。



图 11　模板原型：设备借用的六类字段、顺序节点和版本发布

发布错误定位至字段或节点；条件限定为类型化比较及有界组合，顺序节点无回边。预览和员工录入使用同一份发布定义；停用阻止新提交，不中断旧实例。配置与动态执行部分由本人独立实现。

7.9. 通知与统计

通知中心默认显示全部，支持未读筛选、单条已读及全部已读；全部已读以打开时的服务端边界为准，不误标随后到达的消息。点击通知进入重新鉴权的详情。失败邮件不隐藏站内通知。

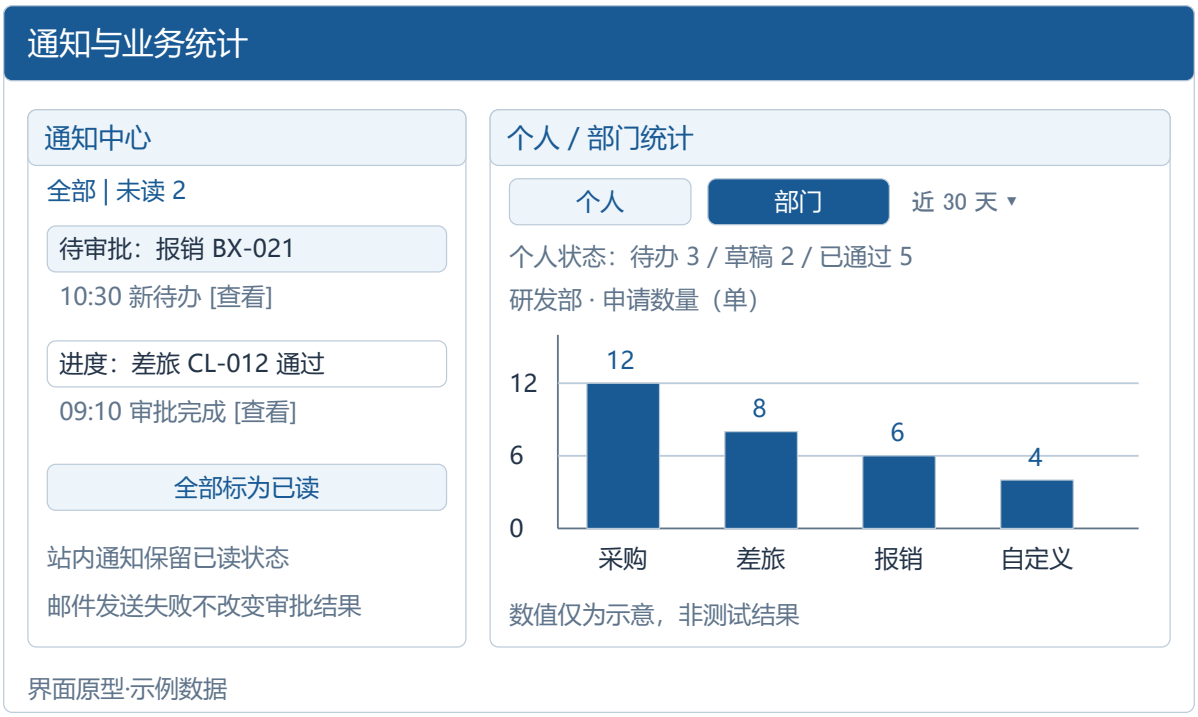


图 12　通知与统计原型：未读列表、个人存量及部门分类图表

统计默认个人视图，授权后增加部门或企业切换。日期范围旁注明“按提交时间”，待办卡片注明“当前”。采购、差旅、报销金额分别展示，不出现混合支出总计；空数据保留坐标及“暂无已提交记录”，加载失败不显示旧数值冒充新结果。

7.10. 小程序

小程序未登录时显示登录与注册入口，沿用账户字段和待确认规则；会话失效返回登录并保留安全页面入口。登录后底部设置申请、待办、通知和我的。申请列表包含进度查询，详情显示时间线。三类业务与启用模板均可新建，管理配置只在桌面完成。多行明细采用卡片，展开当前行时保留其他行的合计摘要。



图 13　小程序原型：报销卡片、票据上传和当前待办处理

拍摄或选择文件后显示进度、失败重试和删除入口，上传完成才允许提交；取消相机权限后仍能选择已有文件。票据预览提供页码或缩放，PDF 可使用平台文档预览，返回不丢失当前表单。



图 14　小程序补充原型：账户入口、申请与通知、模板填写及票据进度查询

适配宽度 320—430 逻辑像素，重点检查 375、390、414 三档及一台安卓、一台 iOS 真机。正文无横向滚动；左右间距 16 逻辑像素，正文不小于 14，主要按钮触控区至少 44×44。

日期使用选择器，金额唤起数字键盘但仍做格式校验；底部按钮预留安全区和键盘避让，不能遮住最后一条费用或错误提示。

前台10秒轮询摘要，通知或待办变化提示条可直接进入有权限详情，用户不用手动刷新；历史消息在通知中心分页查询，不依赖每条弹窗。弱网仅在当前账号的本机草稿区保存未提交输入，不离线排队审批；恢复网络先读取服务器版本，冲突时由用户选择保留本机输入或服务器草稿，不能静默覆盖。切换账号清空本机草稿，过期会话重新登录后再确认恢复。

8 测试与验收

8.1. 测试数据与分层

账户覆盖三个部门、五类角色、跨部门指定审批人和待确认用户。基础演示数据包含两个供应商的采购、三行费用且一行无票的报销、同日及跨日差旅、已发布设备借用模板、审批中与终态样本、旧版本草稿。演示与生产初始化分开，演示账号不在公网生产环境默认启用。

单元测试覆盖金额舍入、阈值等值、日期和权限判定；集成测试使用独立 MySQL 数据库验证约束、迁移、锁、事务回滚及任务去重；端到端测试覆盖桌面主要路径，小程序使用开发者工具与真机。测试报告记录构建版本、环境、账号权限、输入、预期、实际及缺陷，不以本表替代实测结果。

编号	对象	场景与预期
T01	身份	重复用户名/邮箱、短密码拒绝；前后端提示一致；伪造角色与确认部门无效；待确认不可办理，确认后生效
T02	授权	直接请求列表、详情、审批、附件；跨部门及管理员无额外授权拒绝；他人草稿不可见；正文与统计权限分离
T03	采购	两条明细两家报价；非单一来源少于两家、缺线上截图/非最低价理由拒绝；单一来源原因在审批页可见；含运费及其他费用总额正确，差额非零拒绝
T04	差旅	倒置时间、负预算拒绝；同日 1 天、跨月按自然日；获批可关联本人报销，摘要对应原单
T05	报销	三行费用重算；一行多票分别保存票号；无效日期、默认缺票、无票缺原因、重复票、关联他人或未通过单据拒绝；独立说明必填
T06	模板	从管理页新建设备借用含六类字段、两节点；调序与必填生效；无效标识、条件、人员禁止发布，不改代码或数据库
T07	版本	换负责人/阈值/模板新版；旧实例不变，新提交用新配置；旧草稿可按启用模板旧版提交，停用阻止新提交
T08	并发	同版本双批准、中间批准与撤回仅一方成功；核对版本、节点、日志与通知
T09	重试	创建、删除、审批及交接丢失成功响应后同键重试返回原结果；同键异目标/异内容拒绝；删除后不因目标消失先报 404，交接不因自身增加配置版本误报 409
T10	状态	自审、提前审批、终态审批拒绝；驳回理由必填；撤回取消剩余节点；重提有原单关联
T11	文件	伪造后缀、数量/大小超限、越权绑定拒绝；同字节重传不可重复绑定；解绑回滚及复制/清理竞争不删有效文件

编号	对象	场景与预期
T12	通知	四类事件去重及重启保留；双接收人反向流转无锁顺序环；跨端已读刷新；同数量换待办仍刷新；边界 B 与新通知竞争不误读，重复幂等、过期拒绝；邮件租约恢复
T13	统计	逐单对账个人、部门、企业数量及分类型金额；草稿/待办时间口径、区间端点、当前状态和明细权限正确
T14	移动	真机注册登录、四类申请、拍票、审批、进度和通知；前台自动变化、后台邮件；取消权限、断网、会话过期可恢复
T15	部署	空环境启动；重复初始化不覆盖；服务重启保留正文/历史/通知/附件；成组恢复后实际下载票据
T16	跨单预警	相同字节跨单提示、不阻断；重拍不误称可识别；无权限不泄露原单；驳回/撤回单排除；两个草稿先后提交仍提示
T17	超时催办	测试时钟推进至截止前后，前不发、后一分钟内发；重复扫描/重启/双任务不重复；与批准/撤回/改派竞争无旧分配新增催办
T18	管理	确认/拒绝与重申；授权到期、最后管理员保护、主备校验和停用先交接；并发管理仅一方通过旧配置版本；等待锁时被撤权的操作者不得写入，提交与停用竞争不引用失效人员
T19	通用页	草稿保存恢复删除；列表筛选分页；已办按单去重；加载/空/失败/成功/确认状态；改密及重置后旧会话失效
T20	边界	阈值等值及多 0.01 走正确路径；逐行舍入、数量/金额上限、超精度、空明细拒绝；大 ID 不丢精度；草稿键跨单/类型伪造拒绝，提交映射失败回滚正文、绑定与草稿
T21	适配与安全	五档宽度及 130% 字体无关键遮挡；键盘焦点与安全区；会话空闲/绝对到期；伪造 Origin/CSRF、双凭据、XSS、SQL、越权与限流返回约定错误，日志不泄露
T22	留痕	业务账号不能修改/删除审批及审计记录；配置发布与审计同成败；邮件错误及日志不含密码、令牌或 SMTP 密钥

并发测试由两个独立客户端同步发起请求，检查响应与数据库，不只检查页面提示。超时测试使用测试环境可控时钟或专用历史种子，不为演示修改生产时钟或绕过截止规则。T16、T17 均在独立数据集验证后再录屏。

8.2. 性能与复现

目标为 10,000 张申请、20 并发用户下，授权列表和详情 P95 不超过 1 秒，提交与审批 P95 不超过 2 秒；这是验收目标，不是已测数据。用固定随机种子的脚本生成三部门、四类型和各状态数据，保留生成参数及数量校验。k6 进行 2 分钟预热、5 分钟 20 并发测量，读场景与写场景分开；写场景为每个虚拟用户准备独立单据，防止把合法冲突算作吞吐结果。

记录机器 CPU、内存、系统、镜像版本、网络、数据库参数、成功率、P50/P95 及查询计划。列表组合筛选和本人已办分别测量；附件上传下载单独测。响应超目标时核查授权过滤、聚合和索引，不以取消鉴权换速度。

8.3. 需求与验收对应

任务书范围	设计落点	验收证据
通用界面与身份	账户、工作台、会话及管理操作	T01、T18、T19；注册确认与筛选录屏

任务书范围	设计落点	验收证据
三类业务与附件	业务规则、费用模型、绑定和鉴权	T03—T05、T11、T20；明细与票据操作
自定义第四类流程	模板配置、版本与设备借用表单	T06、T07；不改代码的完整新建提交记录
流转与留痕	人员快照、状态、幂等和事务	T08—T10、T22；双客户端与历史核对
查询统计与通知	个人/部门口径、通知及邮件任务	T02、T12、T13；聚合对账和越权结果
移动端与提醒	小程序四类业务、适配、轮询及邮件	T14、T21；安卓/iOS、前台与关闭页面后的录屏
两项增强	相同文件预警、超时催办	T16、T17；有权/无权提示与一次性催办
部署与交付	迁移初始化、Compose、备份恢复	T15；空环境启动、重启和恢复记录

9 部署与实施安排

9.1. 部署、初始化与恢复

Docker Compose 部署 frontend、backend、mysql 三服务。Nginx 提供静态页并代理 API，数据库仅内部网络可达；MySQL 与附件分别使用命名卷。先迁移，再以健康检查开放请求。镜像和依赖锁定版本，提交构建所需文件及环境变量说明。

初始化幂等创建三部门和五类角色，不覆盖已有账号及历史。独立演示配置创建各部门员工与负责人、财务主备、企业负责人主备、管理员和待确认用户，写入三类样例及设备借用模板；给定种子重复执行不重复创建。初始密码由环境注入、只存哈希，演示清单只说明账号职责，不写通用默认密码。

备份时暂停写入，数据库、附件、迁移版本和文件摘要保存同一批次，完成后写标记。恢复校验批次与摘要后再恢复数据库和附件，失败保持维护状态。验收机除验证启动，还要实际打开正文、历史、通知并下载票据。

小程序在11月16日前验证AppID、可用主体、HTTPS证书、请求/上传/下载合法域名和真机访问条件；域名及主体涉及的备案、认证或审核要求按平台实际条件核实，不将开发者工具关闭域名校验当作真机接入完成。课程演示优先使用满足体验版条件的账号，并提前确认体验成员与审核限制，不依赖最后一周公开发布。保留真机访问和邮箱收信记录，不用 H5 页面代替小程序交付。

9.2. 开发安排

时间	工作	完成条件
11 月 9—16 日	设计及原型定稿；AppID、合法域名、真机上传下载、SMTP 收信验证	设计文档提交；外部接入条件确认，形成问题清单
11 月 17—30 日	工程、迁移、身份与管理、草稿、附件、采购；小程序账户壳	采购闭环可用；确认/授权可操作；小程序可登录真机接口
12 月 1—12 日	差旅、报销、自定义模板和实例；并发、版本与跨单预警	T01—T11、T16、T18、T20 通过
12 月 13—20 日	统计、通知、邮件、超时催办及小程序四类办理	T12—T14、T17、T19、T21 通过，两项增强可演示

时间	工作	完成条件
12 月 21—28 日	回归、性能、权限、日志及恢复测试；修复真机交互	T15、T22 通过；阻断缺陷关闭，性能有实测记录
12 月 29 日—1 月 2 日	验收机复现、使用手册、测试报告、演示录制与打包	全套交付核对，2027 年 1 月 3 日前提交

代码、迁移和部署配置按功能单元提交 Git，保留开发过程及版本标签。密钥、数据库卷、上传文件和构建缓存排除在仓库外。自定义表单与流程由本人独立编码，保留分阶段提交和测试记录，不在移动扩展阶段临时复制固定页面替代。

9.3. 风险与处理

风险	处理
小程序接入受限	11 月完成主体、域名与体验成员核实；最先做真机登录和文件传输；遇到审核限制提前处理并记录支持环境，不把工具内运行冒充手机完成
SMTP 不可达或延迟	提前验证发件配置和手机收信；失败保留任务与站内通知，记录重试；演示同时显示任务状态和实际邮件
自定义模块工期	先完成六类字段、两个节点、版本和动态录入；不扩展会签、委托、OCR 或可视化编辑，两项增强在 12 月 20 日前收口
审批或催办竞争	暂停新增功能，核查申请锁、分配版本、唯一约束及原子入队；回归双客户端和任务重启场景
人员停用阻塞	管理页先展示负责人及未完成节点；交接后再停用，保留原人员快照和审计
验收机环境差异	锁定镜像、记录 CPU 架构和端口要求；空目录按手册构建；提前准备依赖及可用镜像，不能只在开发机运行
备份缺少附件	数据库与附件成组校验；恢复测试实际下载票据，缺失则不开业务

9.4. 交付与演示顺序

11 月 16 日提交设计文档。期末包包含课程实验报告封面及报告、设计文档、使用手册、测试报告、源码、Git 日志与版本信息、迁移及初始化数据、Dockerfile 与 Compose 配置、环境变量示例、依赖说明和操作视频。环境示例只保留变量名与用途，不携带真实密钥。

使用手册给出空环境启动、演示账户初始化、登录、管理配置、四类申请、审批、附件、备份恢复和常见错误处理。测试报告附实际环境、数据规模、逐例结果及性能记录；视频中的构建版本与源码标签一致。

次序	演示操作	画面中保留的证据
1	空环境启动、重复初始化、注册并由管理员确认；展示数据授权与审计	Compose 状态、账号待确认转启用、授权差异和审计时间
2	录入两行采购和两家报价；差旅获批后关联三行报销，展示多票及无票例外	字段校验、费用合计、关联摘要及鉴权预览
3	管理页创建并发布设备借用，员工填写提交；改版后对照旧实例	无需代码变更的配置、动态字段、节点与版本
4	双客户端竞争审批与撤回，成功请求重试	一方成功一方冲突，单次有效日志与通知

次序	演示操作	画面中保留的证据
5	手机完成四类申请、拍票、审批和查询；另一账户改变状态	手机前台无需刷新出现变化，通知跳转有权限详情
6	关闭小程序页面，再完成审批；演示跨单同文件与超时节点	手机邮件到达、重复票据有权/无权提示、一次性催办记录
7	核对个人和部门统计；重启后查询，恢复备份并下载票据	分类型金额、持久历史及可读文件

超时催办使用独立演示数据构造已到期节点，视频说明截止时间和当前时间，不将即时新建节点伪装成等待 24 小时。移动端录制保留系统平台与页面状态，邮件录制保留收件时间及对应编号。所有实测证据在实现完成后采集，不以原型图替代运行结果。